

SOC Home Lab

Security Detection Report

Incident Analysis & Response Documentation across the full attack chain
— from reconnaissance to persistent domain compromise.

ANALYST

Sameep Ghelani

DATE

April 2026

INCIDENTS

11 documented

FRAMEWORK

MITRE ATT&CK

ENVIRONMENT

Kali → Windows AD → Splunk on CentOS

TOOLS

Splunk · Sysmon · Wazuh FIM · Impacket · Mimikatz

Executive Summary

This report documents 11 simulated attack scenarios executed in an isolated home lab environment. Each incident covers the attack technique, detection method, SPL query, key IOCs, MITRE ATT&CK mapping, Incident Response procedure from a Tier 1 SOC analyst perspective, and Root Cause Analysis with remediation recommendations.

The attack chain progresses from initial reconnaissance through credential access, execution, persistence, lateral movement, Active Directory attacks, and persistent domain compromise via Golden Ticket — mirroring a realistic threat actor kill chain. All detections are based on observable log artifacts. Defenders alert on access attempts and suspicious behaviour, not confirmed damage.

Network Topology

MACHINE	ROLE	NAT IP	HOST-ONLY IP
Kali Linux	Attacker	192.168.xxx.xx9	192.168.xxx.xx4
Windows 10 Pro	Victim (domain-joined)	—	192.168.xxx.xx3
Windows Server 2016	Domain Controller	—	192.168.xxx.xx2
CentOS	Splunk SIEM	192.168.xxx.xx1	192.168.xxx.xx1

Note on IPs across incidents: Windows endpoints are dual-homed. Early incidents (01–07) reference the NAT-side IP (192.168.xxx.xx0); domain-joined incidents (08–11) reference the host-only IP (192.168.xxx.xx3 / 192.168.xxx.xx2). Both addresses point to the same physical machines.

Detection stack: Splunk Enterprise (SIEM) + Sysmon (endpoint telemetry) + Windows Event Forwarding + Linux auditd + Wazuh (File Integrity Monitoring).

Wazuh FIM: Deployed in real-time on all Windows endpoints — monitoring the `hosts` file, Desktop, and Tools directories for file creation, modification, and deletion. During triage, FIM immediately answers *"did the attacker drop or tamper with any files?"* without manually hunting Sysmon EID 11.

Incidents Overview

#	INCIDENT	SEVERITY	KEY EVENT ID	MITRE TACTIC
01	Port Scan / Recon	MEDIUM	Sysmon EID 3	TA0043 Reconnaissance
02	Brute Force — Linux SSH	HIGH	linux_secure	TA0006 Credential Access
03	Brute Force — Windows SSH	HIGH	EID 4625	TA0006 Credential Access
04	Reverse Shell	CRITICAL	Sysmon EID 1, 3	TA0002 Execution
05	Persistence — Scheduled Task	HIGH	EID 4698	TA0003 Persistence
06	Credential Dumping — LSASS	CRITICAL	Sysmon EID 1	TA0006 Credential Access
07	Lateral Movement — PsExec	CRITICAL	EID 7045, 4624, Sysmon 1	TA0008 Lateral Movement
08	Kerberoasting	HIGH	EID 4769	TA0006 Credential Access
09	Pass-the-Hash	HIGH	EID 4624	TA0008 Lateral Movement
10	DCSync	HIGH	EID 4662	TA0006 Credential Access
11	Golden Ticket	CRITICAL	EID 4672	TA0006 Credential Access

Incident 01 — Port Scan / Recon

Severity: MEDIUM
Attack Tool: Nmap (-sS -A)
Source: 192.168.xxx.xx9 (Kali)
Target: 192.168.xxx.xx0 (Windows)

DETECTION

Sysmon Event ID 3 detected a single source IP hitting more than 5 unique destination ports within a one-minute window. Threshold set above the observed legitimate traffic baseline to minimise false positives. In production this threshold would be baselined over 1–2 weeks before enforcement.

SPL QUERY

```
index=main EventCode=3
| bucket _time span=1m
| stats dc(DestinationPort) as unique_ports by _time, SourceIp, DestinationIp
| where unique_ports > 5
| sort -unique_ports
```

INDICATORS OF COMPROMISE

- Single IP hitting 20+ ports within seconds
- Parallel connection attempts — Nmap signature behaviour
- Ports 22, 135, 139, 445 probed simultaneously
- No scheduled scan or change ticket for the source IP
- Activity occurred outside business hours

MITRE ATT&CK

TA0043 Reconnaissance | T1046 Network Service Discovery

Note: Threshold of 5 suits this lab. In production, baseline legitimate scanner traffic (Nessus, Qualys) and set the threshold just above the observed maximum to reduce false positives.

INCIDENT RESPONSE — TIER 1 SOC ANALYST

STEP	ACTION
1. Alert Review	Confirm EID 3 shows dc(DestinationPort) > 5 within a 1-minute bucket. Note source IP, destination IP, and exact timestamp.
2. Source IP Check	Is the source IP internal or external? Cross-reference the IT scanner list and change ticket system. Is there an active ticket for a scheduled scan?
3. TP/FP Decision	TP: External or unrecognised IP, no change ticket, off-hours, 20+ ports in seconds. FP: Known IT scanner with a valid change ticket during business hours. Document reasoning.
4. Pivot Search	Search the same source IP across all other event IDs in the same window. Look for follow-on EID 4625 (brute force) or Sysmon EID 1 (execution) — recon always precedes exploitation.
5. Document	Record: source IP, destination, port list, timestamp, TP/FP decision and rationale. Attach Splunk export to the ticket.
6. Escalate to T2	If confirmed TP: escalate with source IP, targeted ports, timestamp, and any follow-on activity observed.

ROOT CAUSE ANALYSIS

Root Cause	Ports 22, 135, 139, and 445 reachable from the attacker subnet with no network-level controls blocking reconnaissance.
Vulnerability	No firewall rules or VLAN segmentation preventing external hosts from reaching internal services. Unnecessary ports exposed.
Contributing Factor	Alert threshold not tuned to the environment — unintuned thresholds generate noise or miss low-and-slow scans.
Remediation	1. Firewall: block unsolicited inbound connections from untrusted subnets. 2. VLAN segmentation between attacker-accessible and internal networks. 3. Disable SSH (22) on Windows if not required. 4. Restrict NetBIOS ports to trusted internal ranges. 5. Tune Splunk threshold after baselining legitimate traffic.
Lessons Learned	Detecting recon early is the highest-value intervention — every subsequent attack in this chain depended on information gathered at this stage.

Incident 02 — Brute Force — Linux SSH

Severity: HIGH
Attack Tool: Hydra
Source: 192.168.xxx.xx9 (Kali)
Target: 192.168.xxx.xx1 (CentOS / Splunk)

DETECTION

Linux auth logs (linux_secure sourcetype) — failed password entries extracted via regex, counted per source IP and target username. Any IP exceeding 5 failures is flagged. Non-existent usernames indicate wordlist-based enumeration — an attacker cycling through a dictionary who does not know valid account names.

SPL QUERY

```
index=main sourcetype=linux_secure "Failed password"
| rex "from (?P<src_ip>\d+\.\d+\.\d+\.\d+)"
| rex "for (?P<target_user>\w+) from"
| stats count by src_ip, target_user
| where count > 5
| sort -count
```

INDICATORS OF COMPROMISE

- High volume of failed SSH auth from single IP in short window
- Non-existent usernames — attacker cycling wordlist (user enumeration)
- Rapid sequential attempts consistent with automated tooling (Hydra)
- Multiple target usernames attempted from same source IP
- Check for `Accepted password` from same IP — confirms brute force succeeded

MITRE ATT&CK

TA0006 Credential Access | T1110 Brute Force | T1110.001 Password Guessing

INCIDENT RESPONSE — TIER 1 SOC ANALYST

STEP	ACTION
1. Alert Review	Confirm failed password spike in linux_secure. Note: source IP, target usernames, failure count, timeframe. Are the targeted usernames real accounts or non-existent?
2. Source IP Check	Internal or external? Known admin machine? Any matching change ticket?
3. Check for Success	CRITICAL: Search for <code>Accepted password</code> from the same source IP. If found, severity escalates immediately — document and flag.
4. TP/FP Decision	TP: External IP, non-existent usernames, rapid sequential failures, no change ticket. FP: Internal admin IP with a few failures during a maintenance window.
5. Document	Record: source IP, targeted usernames, failure count, timestamps, and whether a successful login followed. Attach Splunk export.
6. Escalate to T2	Escalate with all findings. If a successful login was found, flag this explicitly — T2 response differs significantly.

ROOT CAUSE ANALYSIS

Root Cause	SSH exposed to the attacker machine with password-based authentication enabled and no brute force protection in place.
Vulnerability	No account lockout or rate limiting after failed attempts. No fail2ban deployed. Password authentication accepted over SSH.
Contributing Factor	No firewall rules restricting which source IPs can reach SSH on this machine.
Remediation	1. Disable password-based SSH — enforce key-based only (PasswordAuthentication no in sshd_config). 2. Deploy fail2ban: auto-block after 5 failures. 3. Firewall: restrict SSH to known admin IPs. 4. Disable root SSH login.
Lessons Learned	Password-based SSH on an internet-facing machine is a critical misconfiguration. Key-based auth eliminates this attack vector entirely.

Incident 03 — Brute Force — Windows SSH

Severity: HIGH
Attack Tool: Hydra
Source: 192.168.xxx.xx9 (Kali)
Target: 192.168.xxx.xx0 (Windows)

DETECTION

Windows Event ID 4625 (Failed Logon) — multiple failures against the same account. Detection pivots to Account_Name count because Source_Network_Address is blank when SSH is the attack vector — a known Windows logging limitation. Logon Types 3, 8, and 9 indicate non-interactive, network-based authentication typical of remote brute force.

SPL QUERY

```
index=main EventCode=4625 Caller_Process_Name="*sshd*"
| stats count by Account_Name, Logon_Type, Caller_Process_Name
| where count > 5
| sort -count
```

INDICATORS OF COMPROMISE

- 5+ failed logons against same account in short window
- Logon Types 3, 8, or 9 — non-interactive, network-based

- Failures followed by a successful logon (EID 4624) from same account
- Activity outside business hours with no change ticket
- Source_Network_Address blank — SSH vector does not populate this field on Windows

MITRE ATT&CK

TA0006 Credential Access | T1110 Brute Force | T1110.001 Password Guessing

Note: Source IP is blank for SSH-based 4625 events on Windows. To recover the attacker IP, correlate 4625 timestamps with Sysmon EID 3 (inbound network connection) at the same timeframe.

INCIDENT RESPONSE — TIER 1 SOC ANALYST

STEP	ACTION
1. Alert Review	Confirm EID 4625 spike. Note: targeted account name, logon type, failure count, timeframe. Blank Source_Network_Address is expected for SSH attacks — not a data gap.
2. Recover Source IP	Cross-reference the 4625 timestamps against Sysmon EID 3 (network connections) in the same window to identify the attacker IP.
3. Check for Success	CRITICAL: Search EID 4624 for the same Account_Name immediately after the failure spike. A successful logon following mass failures is a confirmed breach.
4. TP/FP Decision	TP: Rapid failures against one account, Logon Types 3/8/9, off-hours, no change ticket. FP: User locked out after a password change with a change ticket.
5. Document	Record: targeted account, logon types, failure count, timestamps, recovered source IP, and whether EID 4624 was observed.
6. Escalate to T2	Escalate with account name, failure count, logon types, recovered source IP, and whether a successful logon was observed.

ROOT CAUSE ANALYSIS

Root Cause	Windows OpenSSH exposed with password authentication enabled and no account lockout policy configured.
Vulnerability	No account lockout policy — unlimited password attempts permitted. Password-based SSH accepted.
Logging Gap	Windows does not populate Source_Network_Address in EID 4625 for SSH attacks — known platform limitation. Compensate by correlating with Sysmon EID 3.
Remediation	1. Configure account lockout: 5 failures triggers 30-minute lockout (Group Policy > Account Lockout Policy). 2. Disable password-based SSH — enforce key authentication. 3. Restrict inbound SSH to known admin IPs via Windows Firewall.
Lessons Learned	Knowing to pivot to Sysmon EID 3 to recover the blank source IP demonstrates detection engineering depth beyond running the default query.

Incident 04 — Reverse Shell

Severity: CRITICAL
Attack Tool: Netcat + PowerShell TCP socket
Source: 192.168.xxx.xx9 (Kali) — listener port 4444
Target: 192.168.xxx.xx0 (Windows)

DETECTION

Sysmon EID 1 detected PowerShell launched with `-ExecutionPolicy Bypass` from cmd.exe. Sysmon EID 3 detected powershell.exe establishing outbound TCP to non-standard port 4444. Legitimate software does not need to bypass execution policy at runtime. cmd.exe spawning powershell.exe with bypass flags is a textbook attacker pattern.

SPL QUERY

```
# Outbound connection to non-standard port
index=main EventCode=3 Image="*powershell*"
| where DestinationPort != 80 AND DestinationPort != 443
| table _time, User, Image, DestinationIp, DestinationPort
| sort _time

# ExecutionPolicy Bypass in command line
index=main EventCode=1 Image="*powershell*" CommandLine="*ExecutionPolicy*Bypass*"
| table _time, User, Image, CommandLine, ParentImage
| sort _time
```

INDICATORS OF COMPROMISE

- powershell.exe initiating outbound TCP to external IP
- Non-standard destination port (4444) — not HTTP/HTTPS
- `-ExecutionPolicy Bypass` present in command line
- Script executed from Desktop or Temp path
- cmd.exe as parent process of powershell.exe
- Outbound connection established immediately after script execution

MITRE ATT&CK

TA0002 Execution | TA0011 Command & Control | T1059.001 PowerShell | T1571 Non-Standard Port

Note: Port-based detection misses reverse shells on port 443. Improvement: flag powershell.exe making any outbound connection regardless of port, combined with destination IP reputation and beaconing pattern analysis.

INCIDENT RESPONSE — TIER 1 SOC ANALYST

STEP	ACTION
1. Alert Review	Confirm EID 1 (PowerShell with Bypass) and EID 3 (outbound non-standard port). Verify correlation by User and timestamp — both events should be seconds apart from the same user.
2. Assess Legitimacy	Is there a scheduled task, admin script, or vendor tool that explains this? Legitimate admin scripts are signed and do not require Bypass at runtime.
3. TP/FP Decision	TP: powershell.exe connecting outbound on a non-standard port with -ExecutionPolicy Bypass, no change ticket, unexpected user. Almost always a true positive.
4. Record C2 Details	Note the destination IP and port from EID 3 — this is the attacker's C2 address. Critical for T2 and threat intel enrichment.
5. Document	Record: compromised user, C2 IP and port, timestamp, command line from EID 1, parent process. Open a P1 ticket.
6. Escalate to T2	Escalate immediately as CRITICAL. Include: C2 IP, destination port, compromised user, command line, and timestamp. T2 handles containment and forensic investigation.

ROOT CAUSE ANALYSIS

Root Cause	PowerShell execution policy bypassable with a runtime flag. No application whitelisting in place. Attacker had prior code execution capability on the machine.
Vulnerability	No AppLocker or WDAC policy enforcing Constrained Language Mode. Outbound firewall allowed TCP to arbitrary external IPs on port 4444.
Contributing Factor	No egress filtering — outbound connections to non-business IPs and ports were permitted without inspection.
Remediation	1. Enable PowerShell Constrained Language Mode via AppLocker or WDAC. 2. Set execution policy to AllSigned via Group Policy. 3. Egress firewall: workstations connect outbound only through a proxy — direct TCP to arbitrary ports blocked. 4. Deploy PowerShell Script Block Logging (EID 4104). 5. Enable AMSI for malicious PowerShell detection.
Lessons Learned	A reverse shell gives the attacker an interactive session with the victim's privileges. Every subsequent incident (5, 6, 7) was possible because this shell was not detected and contained in time.

Incident 05 — Persistence — Scheduled Task

Severity: HIGH
Attack Tool: schtasks.exe via reverse shell
Source: 192.168.xxx.xx9 (Kali) — via established reverse shell
Target: 192.168.xxx.xx0 (Windows)

DETECTION

Windows Event ID 4698 — scheduled task created with suspicious keywords in the TaskContent field: ExecutionPolicy, Bypass, shell, temp. Legitimate tasks from trusted software do not embed these strings. Task created under SYSTEM, triggers on logon, and executes a PowerShell payload — ensuring the reverse shell reconnects on every reboot.

SPL QUERY

```
index=main EventCode=4698
| search TaskContent="*ExecutionPolicy*" OR TaskContent="*ByPass*"
  OR TaskContent="*shell*" OR TaskContent="*temp*"
| table _time, Account_Name, Task_Name, TaskContent
| sort _time
```

INDICATORS OF COMPROMISE

- Task named after a legitimate Windows process (masquerading)
- LogonTrigger — task survives reboots and reconnects automatically
- ExecutionPolicy Bypass embedded in task payload
- Task created and running as SYSTEM account
- Created outside business hours with no change ticket
- Task payload points to script in Temp or Desktop path

MITRE ATT&CK

TA0003 Persistence | T1053.005 Scheduled Task / Job

INCIDENT RESPONSE — TIER 1 SOC ANALYST

STEP	ACTION
1. Alert Review	Confirm EID 4698. Review: Task_Name (impersonating a legitimate process?), Account_Name (SYSTEM is immediately suspicious), TaskContent keywords (Bypass, shell, temp).
2. Assess Legitimacy	Is there a change ticket for task creation at this time? Legitimate tasks from trusted software are signed and do not use Bypass in their payload.
3. TP/FP Decision	TP: SYSTEM-created task, Bypass/shell keywords, off-hours, no change ticket, masquerading name. FP: Software installer creating a legitimate update task — verify vendor and change ticket.
4. Check Active Execution	Is the task already running? Check EID 3 for outbound powershell.exe connections at the same timestamp — the payload may already be calling back.
5. Document	Record: task name, creation time, Account_Name, TaskContent, trigger type, and any correlated C2 activity.
6. Escalate to T2	Escalate with task details and any observed C2 activity. T2 will determine whether an active session exists and handle removal and investigation.

ROOT CAUSE ANALYSIS

Root Cause	Attacker had SYSTEM-level access (via reverse shell in Incident 4) with no policy restricting creation of tasks with malicious payloads.
Vulnerability	No AppLocker/WDAC policy blocking script execution from user-writable paths. No real-time EID 4698 alerting existed before this rule was created.
Contributing Factor	Persistence was only possible because the reverse shell (Incident 4) was not contained. Incident 5 is a direct consequence of Incident 4.
Remediation	1. AppLocker/WDAC: block script execution from Temp, Desktop, and user-writable paths. 2. Group Policy: restrict schtasks.exe for non-admin users. 3. Real-time EID 4698 alert — any task with Bypass or shell keywords fires immediately. 4. Audit all existing scheduled tasks regularly.
Lessons Learned	Persistence is established within minutes of initial access. Detect Incident 4 quickly and Incident 5 never occurs.

Incident 06 — Credential Dumping — LSASS

Severity: CRITICAL
Attack Tool: comsvcs.dll MiniDump + Mimikatz
Source: 192.168.xxx.xx0 (Windows) — local attack via established session
Target: 192.168.xxx.xx0 (Windows) — LSASS process targeted

DETECTION

Sysmon EID 1 detected Mimikatz executed with sekurlsa arguments. Sysmon EID 1 also detected rundll32.exe invoking comsvcs.dll MiniDump targeting the LSASS PID. LSASS (Local Security Authority Subsystem Service) holds NTLM hashes, Kerberos tickets, and sometimes plaintext credentials in memory. Extracting these enables pass-the-hash and lateral movement without requiring the plaintext password.

SPL QUERY

```
# Mimikatz binary execution
index=main EventCode=1 Image="*mimikatz*"
| table _time, User, Image, CommandLine | sort _time

# comsvcs.dll MiniDump targeting LSASS
index=main EventCode=1 Image="*rundll32*" CommandLine="*comsvcs*"
| table _time, User, Image, CommandLine | sort _time
```

INDICATORS OF COMPROMISE

- mimikatz.exe executed with sekurlsa arguments

- rundll32.exe invoking comsvcs.dll MiniDump targeting LSASS PID
- Dump file written to `C:\Users\Public\lsass.dmp`
- All activity under interactive admin session
- LSASS access attempt is a critical finding regardless of extraction success
- Follow up: EID 4624 Logon Type 3 on other machines — may indicate stolen credentials in use

MITRE ATT&CK

TA0006 Credential Access | T1003.001 OS Credential Dumping: LSASS Memory

Note: Extraction failed due to Windows 11 24H2 LSASS Protected Process Light (PPL). Detection is based on the attempt — the attempt alone confirms SYSTEM-level access, a critical finding regardless of whether extraction succeeded.

INCIDENT RESPONSE — TIER 1 SOC ANALYST

STEP	ACTION
1. Alert Review	Confirm EID 1 with mimikatz in Image, or rundll32 with comsvcs in CommandLine. When mimikatz.exe is executing on disk this is an automatic CRITICAL — no TP/FP debate.
2. Check Dump File	Note whether a dump file path appears in the CommandLine. If it exists, treat credentials as potentially extracted until confirmed otherwise.
3. Pivot to Lateral Move	Search EID 4624 Logon Type 3 across all other machines filtering for the compromised account or machine IP as source. If stolen hashes are in use, it will appear here.
4. Document	Record: compromised user, command line, dump file path if present, whether PPL was active, and any Logon Type 3 events on other machines. Open a P1 ticket.
5. Escalate to T2	Escalate as CRITICAL immediately. Include: whether dump file exists, active accounts on the machine, and any lateral movement observed. T2 handles isolation and credential resets.

ROOT CAUSE ANALYSIS

Root Cause	Attacker had SYSTEM-level access (consequence of Incidents 4 and 5 not being contained). With SYSTEM privileges, LSASS can be targeted directly.
Vulnerability	LSASS PPL not enabled — default only on Windows 11 24H2+. No Credential Guard deployed. Mimikatz placed on disk without AV detection.
Contributing Factor	No EDR monitoring LSASS handle access. Credential Guard was not deployed.
Remediation	1. Enable Credential Guard via Group Policy — renders LSASS dumps useless even with SYSTEM access. 2. Enable LSASS PPL: HKLM\SYSTEM\CurrentControlSet\Control\Lsa > RunAsPPL = 1 . 3. EDR: alert on any process opening a handle to LSASS. 4. Block known credential dumping tools at AV/EDR layer.
Lessons Learned	Once NTLM hashes are obtained the attacker moves laterally using Pass-the-Hash without ever knowing plaintext passwords. Incident 7 is a direct consequence of Incident 6 not being stopped.

Incident 07 — Lateral Movement — PsExec

Severity: CRITICAL
Attack Tool: Impacket PsExec
Source: 192.168.xxx.xx9 (Kali)
Target: 192.168.xxx.xx0 (Windows)

DETECTION

Impacket PsExec copies a randomly named binary to C:\Windows\ over SMB (Admin\$ share), creates a temporary Windows service as NT AUTHORITY\SYSTEM to execute it, then deletes the service immediately. Legitimate Sysinternals PsExec always drops PSEXESVC.exe — Impacket drops a randomly named binary. This is the primary detection differentiator. Three correlated events confirm the attack: EID 7045, Sysmon EID 1, and EID 4624 Logon Type 3.

SPL QUERY

```
# Random binary spawned by services.exe as SYSTEM
index=main EventCode=1 ParentImage="*services.exe*" Image="C:\\Windows\\*.exe"
| where NOT match(Image, "(?i)(svchost|spssvc|TrustedInstaller|msiexec)")
| table _time, User, Image, CommandLine, ParentImage | sort _time

# New service created / deleted rapidly
index=main EventCode=7045
| table _time, ServiceName, ServiceFileName | sort _time

# Logon Type 3 – correlate timestamps
index=main EventCode=4624 Logon_Type=3
| table _time, Account_Name, Logon_Type, IPAddress | sort _time
```

INDICATORS OF COMPROMISE

- Randomly named executable in `C:\Windows\` — legitimate PsExec uses `PSEXESVC.exe`
- Binary spawned directly by services.exe as NT AUTHORITY\SYSTEM
- Service created and deleted within seconds — Impacket cleanup behaviour
- Logon Type 3 from external IP at same timestamp as service creation
- Source IP not belonging to known IT team machines, no change ticket

MITRE ATT&CK

TA0008 Lateral Movement | T1021.002 SMB/Admin Shares | T1543.003 Windows Service

INCIDENT RESPONSE — TIER 1 SOC ANALYST

STEP	ACTION
1. Alert Review	Correlate all three events by timestamp: EID 7045, Sysmon EID 1 (binary from services.exe), EID 4624 Logon Type 3. All three in the same minute window confirms Impacket PsExec.
2. Binary Name Check	Check the Image field in Sysmon EID 1 — <code>PSEXESVC.exe</code> indicates legitimate use. A random string (e.g. xvtqrs.exe) confirms Impacket. This is the key differentiator.
3. Identify Account	Which account was used for Logon Type 3? Cross-reference with any previously compromised accounts. Flag it as fully compromised.
4. TP/FP Decision	TP: Random binary name, external source IP, no change ticket. FP: IT team using legitimate PsExec — PSEXESVC.exe present, valid change ticket, known IT IP.
5. Scope Assessment	Search for the same Logon Type 3 pattern on ALL other machines. Map every machine the attacker may have reached.
6. Document	Record: binary name, source IP, account used, timestamp, service name from EID 7045, all other machines showing Logon Type 3 from the same source.
7. Escalate to T2	Escalate as CRITICAL with: attacker IP, account used, binary name, all machines showing Logon Type 3 from attacker IP.

ROOT CAUSE ANALYSIS

Root Cause	Attacker obtained NTLM hashes via LSASS dump (Incident 6) and used Pass-the-Hash over SMB. Admin\$ share accessible from the attacker machine.
Vulnerability	Admin\$ SMB share reachable from non-domain machines. No SMB signing enforced. Compromised account had local admin rights on the target.
Contributing Factor	Credential dump in Incident 6 was not contained. Once hashes are exfiltrated, lateral movement follows within minutes.
Remediation	1. Disable Admin\$ on workstations via Group Policy. 2. Enforce SMB signing. 3. Tiered admin model: admin accounts should not have local admin rights across all workstations. 4. Deploy Credential Guard to prevent pass-the-hash. 5. Network segmentation: workstations should not SMB directly to each other.
Lessons Learned	The PsExec service creates and deletes itself in seconds. Without real-time correlation of EID 7045 + Sysmon EID 1 + EID 4624, this passes completely unnoticed.

Incident 08 — Kerberoasting

Severity: HIGH

Attack Tool: Impacket GetUserSPNs

Source: 192.168.xxx.xx4 (Kali)

Target: 192.168.xxx.xx2 (DC — WIN-N15VPE2DLF9.myhomelab.local)

DETECTION

Any domain user can request a Kerberos service ticket for any SPN-registered account — this is by design in Active Directory. The attacker forces RC4 encryption (0x17) instead of AES (0x12) to obtain a hash crackable offline with hashcat. Event ID 4769 with `Ticket_Encryption_Type=0x17` is the detection trigger.

SPN targeted: `MSSQLSvc/WIN-N15VPE2DLF9.myhomelab.local:1433` (service account: sqlsvc)

SPL QUERY

```
index=main EventCode=4769 Ticket_Encryption_Type=0x17
| table _time, Account_Name, Service_Name, Ticket_Encryption_Type, Client_Address
| sort -_time
```

INDICATORS OF COMPROMISE

- EID 4769 with `Ticket_Encryption_Type=0x17` (RC4) — modern AD uses AES (0x12)
- Requesting account: Lisa@MYHOMELAB.LOCAL (low-privilege domain user)
- Targeted service: sqlsvc (LastLogon: never — unmonitored service account)
- Client_Address: `::ffff:192.168.xxx.xx4` (Kali — non-domain machine)
- Failure_Code: 0x0 — ticket issued successfully, hash retrievable offline
- SPN publicly enumerable by any domain user — no special permissions required

MITRE ATT&CK

TA0006 Credential Access | T1558.003 Steal or Forge Kerberos Tickets: Kerberoasting

Note: Hash cracking via rockyou.txt was unsuccessful (admin@123 not in wordlist). Alert on ANY EID 4769 with 0x17 regardless of cracking outcome — the RC4 request is the attack, not the offline crack.

INCIDENT RESPONSE — TIER 1 SOC ANALYST

STEP	ACTION
1. Alert Review	Confirm EID 4769 with Ticket_Encryption_Type=0x17. Note: requesting account (Lisa), targeted service (sqlsvc), Client_Address (Kali IP), Failure_Code (0x0 = ticket issued).
2. RC4 Significance	Modern AD uses AES (0x12). RC4 (0x17) is only requested when an attacker forces a downgrade to get a crackable hash. No legitimate modern application requests RC4.
3. Scope Check	How many SPNs were requested? One = targeted attack. Multiple in rapid succession = full sweep of all service accounts. Run the query without the encryption filter to check.
4. Check Lisa's Account	Lisa's credentials were used. Is her account showing other unusual activity? Flag Lisa's account alongside the service account.
5. TP/FP Decision	Almost always TP. Only exception: legacy systems (pre-Windows Server 2008) that legitimately use RC4 — verify whether any exist before closing as FP.
6. Document	Record: requesting account, targeted service, Client_Address, timestamp, number of SPNs requested, Failure_Code.
7. Escalate to T2	Escalate with full details. T2 will reset sqlsvc password immediately, audit all SPNs, and investigate Lisa's account for signs of compromise.

ROOT CAUSE ANALYSIS

Root Cause	Service account sqlsvc registered with an SPN and configured with a weak password. RC4 encryption not disabled on the domain.
Vulnerability	sqlsvc password was weak and offline-crackable. RC4 not disabled — modern environments should enforce AES-only. sqlsvc had no login activity (LastLogon: never) making it an unmonitored target.
Contributing Factor	sqlsvc over-privileged relative to its function. No alerting on EID 4769 with RC4 before this rule was created.
Remediation	1. Use Group Managed Service Accounts (gMSA) — Windows auto-rotates the password every 30 days, rendering Kerberoasting useless. 2. Service account passwords: minimum 25 characters, randomly generated. 3. Enforce AES-only: set msDS-SupportedEncryptionTypes = 24 on all service accounts. 4. Audit all SPNs and remove those registered on high-privilege accounts. 5. Alert on all EID 4769 with 0x17.
Lessons Learned	Kerberoasting is silent from the DC — it looks like a normal ticket request. The only detection signal is the RC4 downgrade. gMSA adoption eliminates this attack vector entirely.

Incident 09 — Pass-the-Hash

Severity: HIGH

Attack Tool: Impacket PsExec with NTLM hash

Source: 192.168.xxx.xx4 (Kali)

Target: 192.168.xxx.xx3 (Windows 10 Pro)

DETECTION

Windows Event ID 4624 (Successful Logon) with Logon Type 3 (network logon) from an external IP, where the Logon_Process field shows `NtLmSsp` instead of `Kerberos`. In a healthy domain environment, administrator logins between machines use Kerberos by default. NTLM authentication from a non-domain IP is the smoking gun — the attacker is using a raw NTLM hash, not a password, and has no Kerberos ticket to present.

NTLM hash used: Administrator:570a9a65db8fba761c1008a51d4c95ab (obtained via LSASS dump in Incident 6)

SPL QUERY

```
index=main EventCode=4624 Logon_Type=3
| search Logon_Process="NtLmSsp" Account_Name="Administrator"
| table _time, Account_Name, Logon_Type, src_ip, Workstation_Name, Logon_Process
| sort -_time
```

INDICATORS OF COMPROMISE

- EID 4624 Logon Type 3 with `Logon_Process=NtLmSsp` — NTLM used instead of Kerberos
- Account_Name: Administrator
- src_ip: 192.168.xxx.xx4 (Kali — non-domain machine)
- Workstation_Name: blank — attacker machine is not domain-joined
- No preceding interactive logon (EID 4648) for the same account
- NTLM auth from external IP — legitimate domain admins authenticate via Kerberos

MITRE ATT&CK

TA0008 Lateral Movement | T1550.002 Pass-the-Hash

Note: Pass-the-Hash requires zero cracking — the NTLM hash is the credential. The attacker obtained the Administrator hash in Incident 6 and used it directly against Windows 10 over SMB. No plaintext password was ever known.

INCIDENT RESPONSE — TIER 1 SOC ANALYST

STEP	ACTION
1. Alert Review	EID 4624 Logon Type 3 from external IP with Logon_Process = NtLmSsp. In a domain environment, admin logins between machines use Kerberos by default. NTLM from a non-domain IP is immediately suspicious.
2. Key Fields	Account_Name: Administrator. src_ip: 192.168.xxx.xx4 (Kali). Logon_Type: 3 (network). Logon_Process: NtLmSsp. Workstation_Name: blank (attacker machine not domain-joined).
3. NtLmSsp Significance	NtLmSsp confirms NTLM authentication was used. The attacker never needed the plaintext password — the hash alone is sufficient. This is Pass-the-Hash.
4. Scope Check	Which machines did this source IP authenticate to? Check all EID 4624 Logon Type 3 events from the same IP across all hosts. Determine lateral movement scope.
5. Correlate with Incident 6	This attack was enabled by the LSASS dump in INC-006. The hash obtained there was used directly here. Containment of INC-006 would have prevented this.
6. TP/FP Decision	TP. NtLmSsp Logon Type 3 from a non-domain IP authenticating as Administrator is not legitimate activity in this environment.
7. Document	Record: source IP, account used, Logon_Process field, timestamp, all machines with matching Logon Type 3 from the same IP. Link to INC-006. Open a P1 ticket.
8. Escalate to T2	Escalate with correlation to INC-006. T2 will: rotate Administrator password, force Kerberos-only auth, investigate full lateral movement scope, and isolate affected machines.

ROOT CAUSE ANALYSIS

Root Cause	NTLM hash for Administrator obtained via LSASS dump (INC-006) and used directly for lateral movement without cracking.
Vulnerability	NTLM authentication permitted from non-domain machines. Admin\$ SMB share accessible from external IPs. No SMB signing enforced.
Contributing Factor	INC-006 credential dump was not contained. A single Administrator hash grants access to all machines where that account exists with the same password.
Remediation	1. Deploy Credential Guard to protect NTLM hashes in memory. 2. Enforce SMB signing to prevent relay attacks. 3. Disable NTLM where Kerberos is available (Group Policy). 4. Implement tiered admin model — domain admin accounts never used on workstations. 5. Network segmentation to restrict SMB access between workstations.
Lessons Learned	Pass-the-Hash requires zero cracking — the hash is the credential. Containing credential dumps immediately is critical. A single unrotated hash provides persistent lateral movement capability across every machine sharing that account.

Incident 10 — DCSync

Severity: HIGH

Attack Tool: Impacket secretsdump (DRSUAPI method)

Source: 192.168.xxx.xx4 (Kali)

Target: 192.168.xxx.xx2 (Domain Controller)

DETECTION

DCSync abuses Active Directory's built-in Directory Replication Service (DRSUAPI) protocol. The attacker impersonates a Domain Controller and requests all domain password hashes from the real DC — including the krbtgt hash. The DC complies because the request uses a legitimate replication protocol and the attacker holds domain admin credentials.

No code runs on the DC. No files are dropped. No service is created. The attack is a network-level replication request — making it extremely difficult to detect without specific AD object-level auditing configured.

Correct detection: Event ID 4662 with DS-Replication GUIDs (1131f6aa , 1131f6ab) from a source IP that is not a Domain Controller.

Detection gap note: EID 4662 did not fire on Windows Server 2016 in this lab despite correct ADSI object auditing and Directory Service Replication audit policy configuration. This is a documented real-world limitation of Windows Server 2016 in certain VM environments. The detection gap is recorded accurately — a documented gap is more professionally valuable than a fabricated detection.

SPL QUERY

```
index=main EventCode=4662
| search Properties="*1131f6aa*" OR Properties="*1131f6ab*"
| table _time, Account_Name, Object_Name, Properties
| sort -_time
```

INDICATORS OF COMPROMISE

- EID 4662 with DS-Replication-Get-Changes GUIDs (1131f6aa , 1131f6ab) from non-DC source
- Account_Name: domain admin account used (Administrator)
- Source IP is not a registered Domain Controller IP
- Large volume of NTLM hashes retrieved in short timeframe
- krbtgt hash retrieved — enables Golden Ticket attacks
- No corresponding DC-to-DC replication scheduled at that time

MITRE ATT&CK

TA0006 Credential Access | T1003.006 DCSync

Note: EID 4662 did not generate in this lab on Windows Server 2016 despite correct audit policy. In production, Microsoft Defender for Identity (formerly ATA) detects DCSync at the network level by identifying DRSUAPI calls from non-DC machines — providing detection independent of Windows event logging.

INCIDENT RESPONSE — TIER 1 SOC ANALYST

STEP	ACTION
1. Attack Summary	Attacker used DRSUAPI to impersonate a DC and pull all domain hashes including krbtgt, Administrator, and all service accounts. All domain credentials must be treated as compromised.
2. Hashes Obtained	Administrator, krbtgt, sqlsvc, lisa, john, and all machine account hashes were retrieved. krbtgt hash enables Golden Ticket attacks — persistent, undetectable domain access.
3. Severity Assessment	Critical severity. krbtgt compromise enables forged Kerberos tickets valid for any user, any resource, any duration. The domain is fully compromised.
4. Detect in Splunk	Search EID 4662 for DS-Replication GUIDs. If 4662 is not generating, check Microsoft Defender for Identity or network-level DRSUAPI detection.
5. Document	Record: account used, source IP, timestamp, hashes confirmed retrieved, detection gap if 4662 produced no events. Open a P1 ticket and escalate immediately.
6. Escalate to T2	Escalate as CRITICAL. T2 actions: reset krbtgt password twice (invalidates all existing tickets), rotate all service account passwords, investigate privilege escalation path, initiate full domain compromise response.

ROOT CAUSE ANALYSIS

Root Cause	Domain Administrator credentials compromised (via Pass-the-Hash from INC-009) and used to abuse AD replication protocol to extract all domain hashes.
Vulnerability	Any account with DS-Replication-Get-Changes-All permission can perform DCSync. Built-in Administrator always has this right. No detection was in place for replication from non-DC machines.
Contributing Factor	Chain of uncontained incidents: INC-006 (LSASS dump) → INC-009 (Pass-the-Hash) → INC-010 (DCSync) → INC-011 (Golden Ticket). DCSync yielded the krbtgt hash which directly enabled persistent domain access via forged Kerberos tickets.
Detection Gap	EID 4662 did not fire on Windows Server 2016 in this lab environment despite correct audit policy configuration. This is documented as a real-world logging limitation. Production environments should validate EID 4662 generation via purple team exercises before relying on this detection.
Remediation	1. Reset krbtgt password twice to invalidate all existing Kerberos tickets. 2. Revoke all active Kerberos tickets domain-wide. 3. Rotate all service account and admin passwords. 4. Implement tiered admin model — Domain Admin accounts never used on workstations. 5. Validate EID 4662 detection in production via purple team. 6. Deploy Microsoft Defender for Identity for network-level DCSync detection.
Lessons Learned	DCSync is stealthy — it uses a legitimate AD protocol with no code executed on the DC. The real prevention is stopping privilege escalation earlier in the chain. If INC-006 (LSASS dump) had been contained, neither INC-009 nor INC-010 would have been possible.

Incident 11 — Golden Ticket

Severity: CRITICAL

Attack Tool: Impacket ticketer + psexec

Source: 192.168.xxx.xx4 (Kali)

Target: 192.168.xxx.xx2 (Domain Controller)

Pre-requisite: krbtgt NTLM hash obtained via DCSync (INC-010)

DETECTION

The Golden Ticket attack uses the krbtgt NTLM hash to forge a Ticket Granting Ticket (TGT) entirely offline — without any interaction with the Domain Controller. The forged ticket is self-signed using the krbtgt key, so the DC cannot distinguish it from a legitimate ticket.

Because the KDC never issued the ticket, **no EID 4768 (TGT Request) is generated**. The only observable evidence is **EID 4672 (Special Privileges Assigned)** firing for an account that does not exist in Active Directory.

Lab confirmed: forged ticket created for `fakeadmin` (non-existent user). DC accepted the ticket and granted a SYSTEM shell. EID 4672 fired 4 times. EID 4768: 0 events.

SPL QUERY

```
# PRIMARY DETECTION – EID 4672 for account with no AD existence
index=main EventCode=4672
| stats count by Account_Name
| search NOT [
    search index=main EventCode=4720
    | stats count by Account_Name
    | fields Account_Name
]

# DIRECT SEARCH – known phantom account
index=main EventCode=4672 Account_Name="fakeadmin"
| table _time, Account_Name, Privileges
| sort -_time

# CONFIRM OFFLINE FORGERY – no 4768 should exist
index=main EventCode=4768 Account_Name="fakeadmin"
| table _time, Account_Name, Client_Address
| sort -_time
# Expected: 0 events – proves ticket was never issued by KDC
```

INDICATORS OF COMPROMISE

- EID 4672 for an account that does not exist in Active Directory
- **No corresponding EID 4768** — ticket was forged offline, KDC never issued it
- Account_Name does not appear in `Get-ADUser -Filter *` output
- SYSTEM shell obtained on DC from non-domain machine
- Default Golden Ticket validity is 10 years — anomalous ticket lifetime in Defender for Identity

MITRE ATT&CK

TA0006 Credential Access | T1558.001 Golden Ticket | TA0008 Lateral Movement

Note: Standard Kerberos logging (EID 4768/4769) only covers tickets issued by the KDC. Golden Ticket bypasses the KDC entirely. Microsoft Defender for Identity detects Golden Tickets via anomalous ticket lifetimes (10 years vs normal 10 hours) and forged PAC structure analysis — capabilities beyond basic Windows event logging.

INCIDENT RESPONSE — TIER 1 SOC ANALYST

STEP	ACTION
1. Alert Review	EID 4672 for an account that does not exist in AD. Confirm by running <code>Get-ADUser fakeadmin</code> on the DC — "cannot find object" confirms phantom account.
2. Check for 4768	Search EID 4768 for the same account name. Zero results confirms the ticket was forged offline — this is the defining characteristic of a Golden Ticket.
3. Severity Assessment	Automatic CRITICAL. A forged TGT accepted by the DC means the attacker has full domain access as any user with no expiry. This is complete domain compromise.
4. Scope Assessment	Check EID 4672 across all DCs for the same account name. Check EID 4624 Logon Type 3 from the attacker IP across all machines to map movement.
5. Pre-requisite Trace	Golden Ticket requires the krbtgt hash. Trace back to DCSync (INC-010) — if DCSync was not detected and contained, Golden Ticket was inevitable.
6. Document	Record: phantom account name, timestamp of 4672 events, absence of 4768, source IP, SYSTEM shell on DC confirmed. Open P1 ticket immediately.
7. Escalate to T2	Escalate as CRITICAL. T2 actions: reset krbtgt password twice with a minimum 10-hour gap between resets, invalidate all Kerberos tickets domain-wide, rotate all privileged account passwords, deploy Defender for Identity.

ROOT CAUSE ANALYSIS

Root Cause	krbtgt NTLM hash obtained via DCSync (INC-010) enabled offline forgery of Kerberos tickets with no DC interaction required. This is the direct consequence of INC-010 not being contained.
Attack Chain	INC-006 (LSASS dump) → INC-009 (Pass-the-Hash to DC) → INC-010 (DCSync, obtained krbtgt) → INC-011 (Golden Ticket, SYSTEM on DC as ghost user). Four-step chain from workstation to persistent domain-level access.
Why Detection Is Hard	No EID 4768 is generated because the KDC never issued the ticket. The only observable artifact is EID 4672 for an unknown account — detectable only if the SOC actively cross-references privilege events against the AD user directory.
Vulnerability	No mechanism prevents an attacker with the krbtgt hash from forging tickets offline. This is a fundamental Kerberos design characteristic, not a misconfiguration.
Remediation	1. Reset krbtgt password twice with a 10-hour gap between resets (single reset is insufficient — old hash remains cached for the ticket lifetime). 2. Invalidate all Kerberos tickets domain-wide. 3. Rotate all admin and service account passwords. 4. Deploy Microsoft Defender for Identity for Golden Ticket anomaly detection (ticket lifetime analysis, PAC validation). 5. Implement tiered admin model — prevent domain admin credential exposure on workstations. 6. Alert on EID 4672 for accounts not present in AD as an ongoing detection rule.
Lessons Learned	Golden Ticket is the endgame of Active Directory compromise. Once an attacker has the krbtgt hash they have persistent, stealthy domain access that survives password resets of every account except krbtgt itself. The only effective prevention is stopping DCSync in INC-010 — by the time a Golden Ticket is forged, the domain is fully compromised.

Detection & IR Summary

#	INCIDENT	SEVERITY	KEY EVENT ID	T1 ACTION	RCA FIX
01	Port Scan	MEDIUM	Sysmon EID 3	Pivot to follow-on events, escalate if TP	Firewall + Segmentation
02	Brute Force Linux	HIGH	linux_secure	Check for success, escalate with findings	fail2ban + Key Auth only
03	Brute Force Windows	HIGH	EID 4625	Correlate EID 3 for source IP, escalate	Account Lockout GPO
04	Reverse Shell	CRITICAL	Sysmon EID 1, 3	Record C2 IP, escalate as P1 immediately	AppLocker + Egress FW
05	Persistence Task	HIGH	EID 4698	Check active C2, escalate with task detail	AppLocker + Least Priv
06	Cred Dump LSASS	CRITICAL	Sysmon EID 1	Pivot to Logon Type 3, escalate as P1	Credential Guard + PPL
07	Lateral Move PsExec	CRITICAL	EID 7045, 4624	Check binary name, scope all machines	SMB Signing + Tiered Admin
08	Kerberoasting	HIGH	EID 4769	Check SPN scope, flag Lisa, escalate	gMSA + AES-Only
09	Pass-the-Hash	HIGH	EID 4624	Check NtLmSsp, scope all machines, correlate INC-006	Credential Guard + NTLM Disable
10	DCSync	HIGH	EID 4662	Escalate as CRITICAL, reset krbtgt x2	Defender for Identity + Tiered Admin
11	Golden Ticket	CRITICAL	EID 4672	Verify no 4768, escalate as CRITICAL, reset krbtgt x2	Defender for Identity + Reset krbtgt